Vulnerability Assessment Report

Target: OWASP Juice Shop (Heroku)

Date: 29/03/2026

Project: FUTURE_CS_01

Author: Saket Singh

Table of Contents

1. **Confidentiality Statement**
2. **Disclaimer**
3. **Assessment Overview**
4. **Assessment Components**
5. **Finding Severity Ratings**
6. **Scope**
7. **Executive Summary**
8. **Scan Summary**
9. **Test Findings**
10. **Screenshots**
11. **Recommendations and Conclusion**
12. **Conclusion**

Confidentiality Statement

This document is prepared exclusively for academic and internship purposes under the Future Interns Cyber Security program. Redistribution or use outside this scope requires prior consent.

Disclaimer

This assessment represents a snapshot in time. Findings reflect the state of the Juice Shop application during testing and may not account for changes after the assessment.

Assessment Overview

Between March 28–29, 2026, a vulnerability assessment was conducted on OWASP Juice Shop hosted on Heroku. The methodology followed OWASP Testing Guide v4 and NIST SP 800-115.

Phases included:

- Planning → Defined scope and goals.
- Discovery → Reconnaissance with Nmap and DNS lookups.
- Analysis → Passive scanning with OWASP ZAP.
- Reporting → Documenting vulnerabilities, risks, and recommendations using Canva.

Finding Severity Ratings

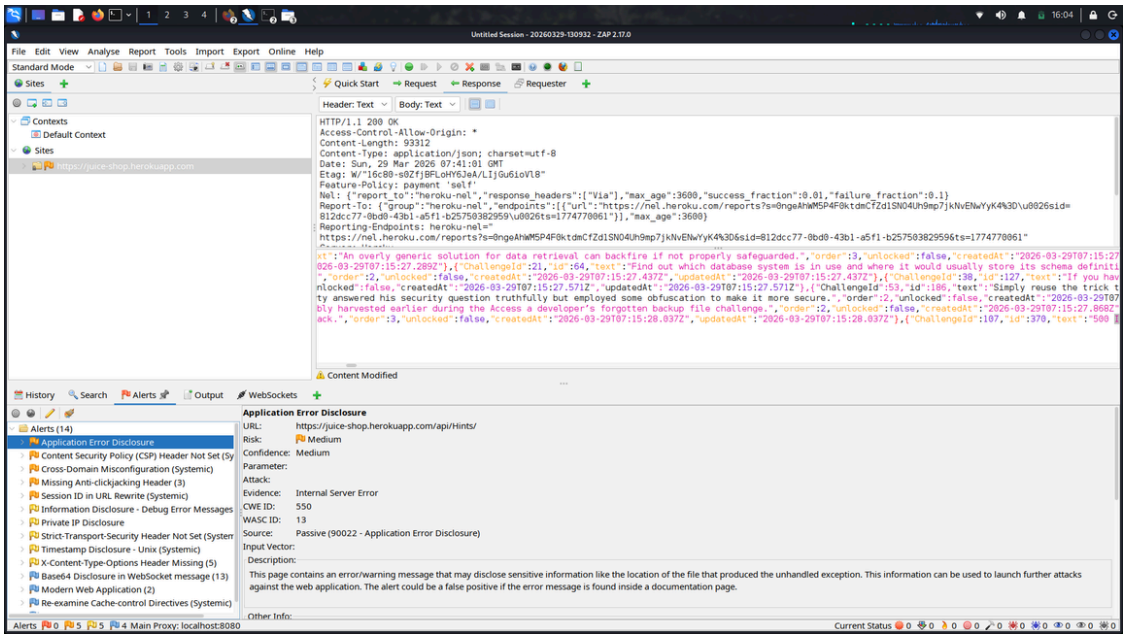
Severity	Definition
High	Exploitable, risk of data exposure or compromise
Medium	Misconfigurations or missing protections
Low	Informational, minor exposure

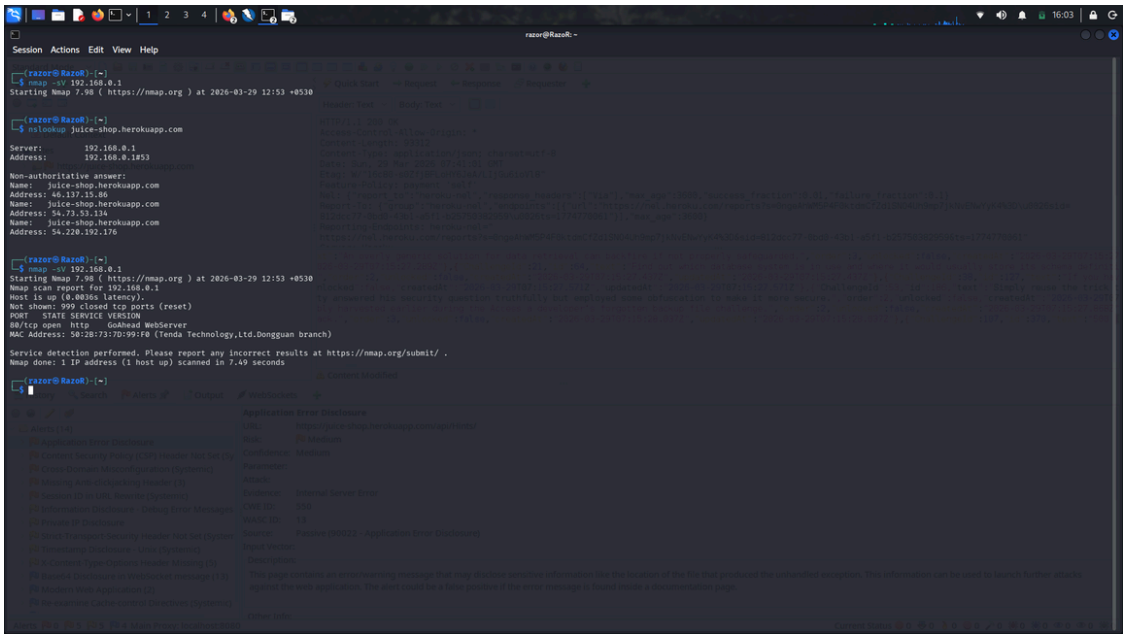
Scope

- Target Application: https://juice-shop.herokuapp.com
- Hosting: Heroku cloud infrastructure

Executive Summary

The Juice Shop application was found to have multiple vulnerabilities, primarily related to missing security headers, information disclosure, and weak session management. While no critical exploit was observed in passive scanning, several high-risk issues were identified that could be leveraged in real-world attacks.





Scan Summary

Sl. No	Vulnerability	Recommendation	Severity
1	Application Error Disclosure	Suppress detailed error messages	Medium
2	Missing Security Headers (CSP, HSTS, X-Frame-Options)	Implement modern headers	High
3	Cross-Domain Misconfiguration (CORS)	Restrict origins to trusted domains	Medium
4	Session ID in URL	Use secure cookies/session tokens	High
5	Information Disclosure (Debug Errors)	Disable debug mode in production	Medium
6	Timestamp Disclosure	Remove unnecessary metadata	Low
7	Weak Cache-Control	Strengthen caching rules	Low
8	X-Content-Type-Options Missing	Add nosniff header	Medium

Test Findings

1) Application Error Disclosure (Medium)

Description: Error messages reveal backend details.

Impact: Attackers can use this information to craft targeted exploits.

System: /api/Hints/

Recommendation: Replace with generic error pages.

2) Missing Security Headers (High)

Description: No CSP, HSTS, or anti-clickjacking headers present.

Impact: Increases risk of XSS, clickjacking, and insecure connections.

System: All pages.

Recommendation: Add CSP, HSTS, and X-Frame-Options headers.

3) Cross-Domain Misconfiguration (Medium)

Description: Access-Control-Allow-Origin: * allows all domains.

Impact: Any site can request Juice Shop data.

System: API responses.

Recommendation: Restrict CORS to trusted domains.

4) Session ID in URL (High)

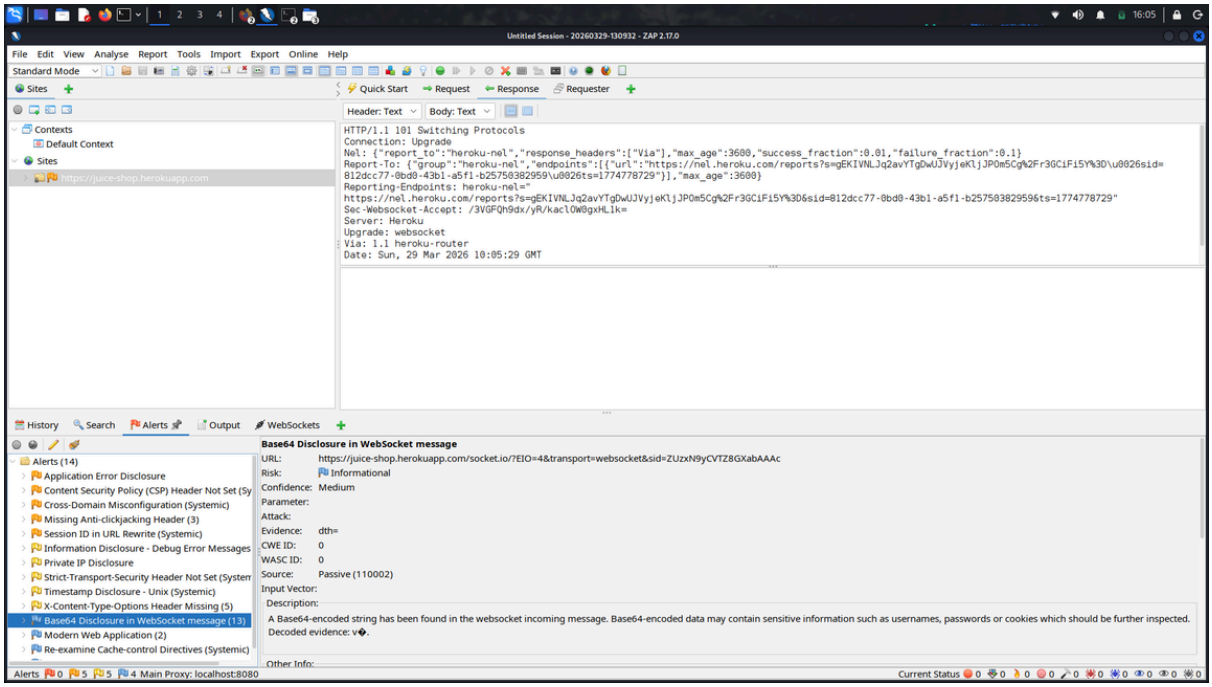
Description: Session tokens visible in URL.

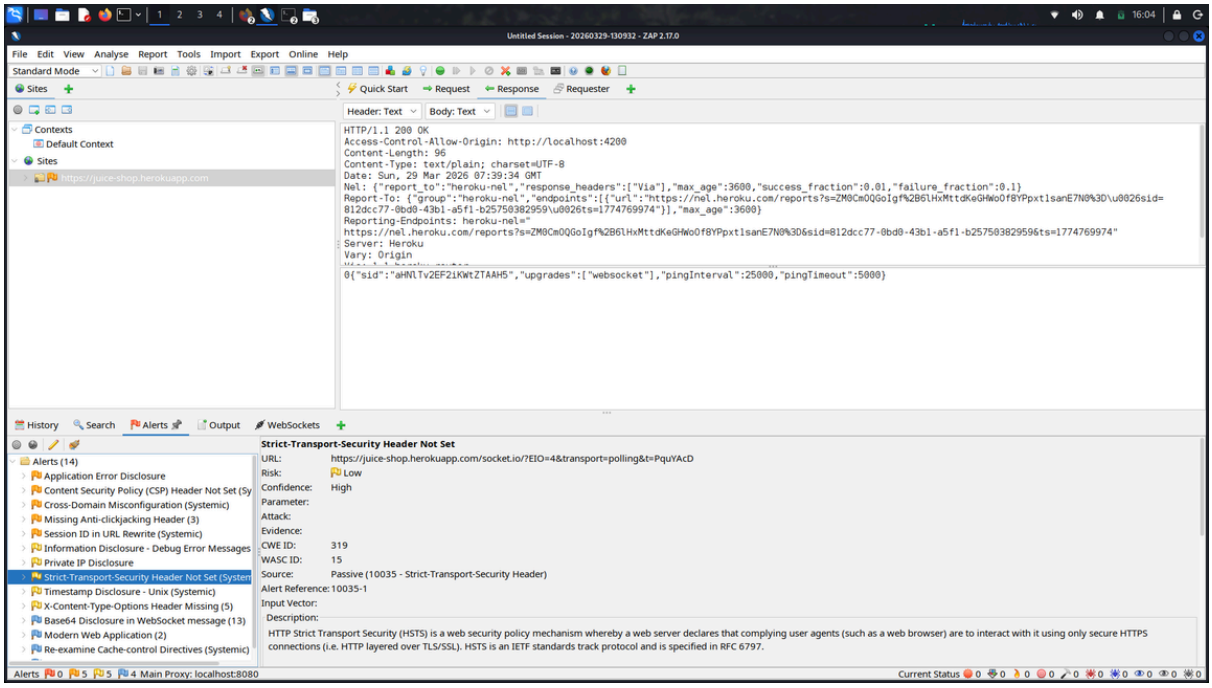
Impact: Tokens may leak via logs or shared links.

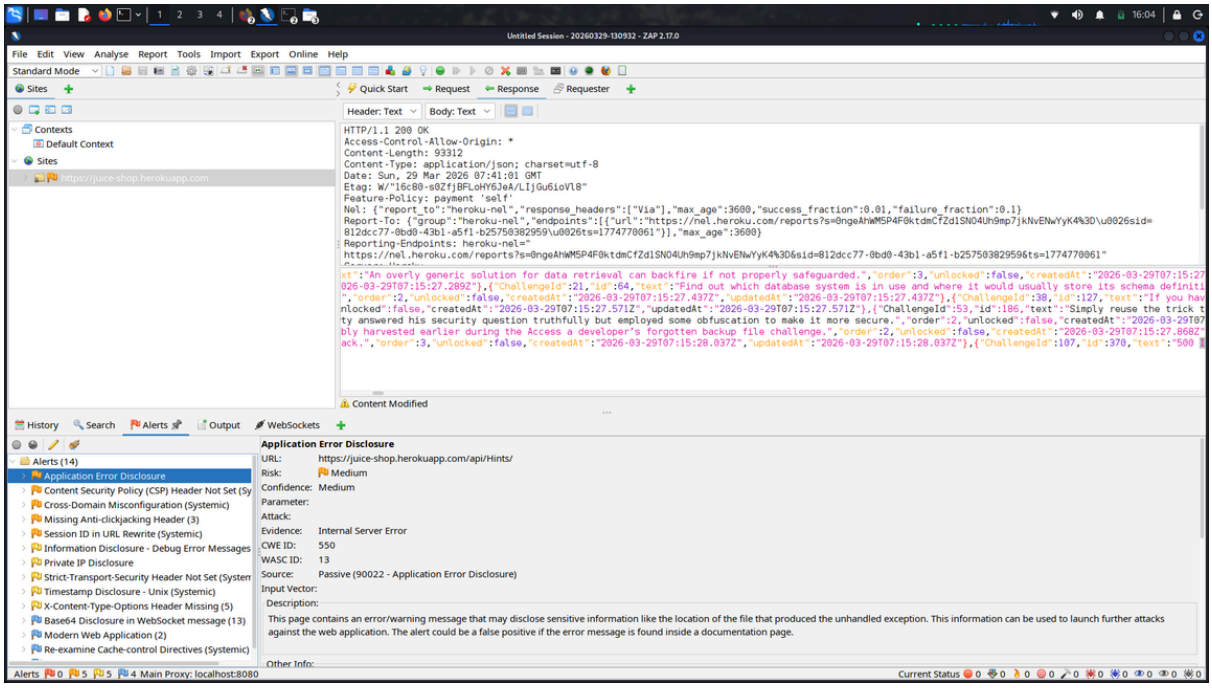
System: Login/session handling.

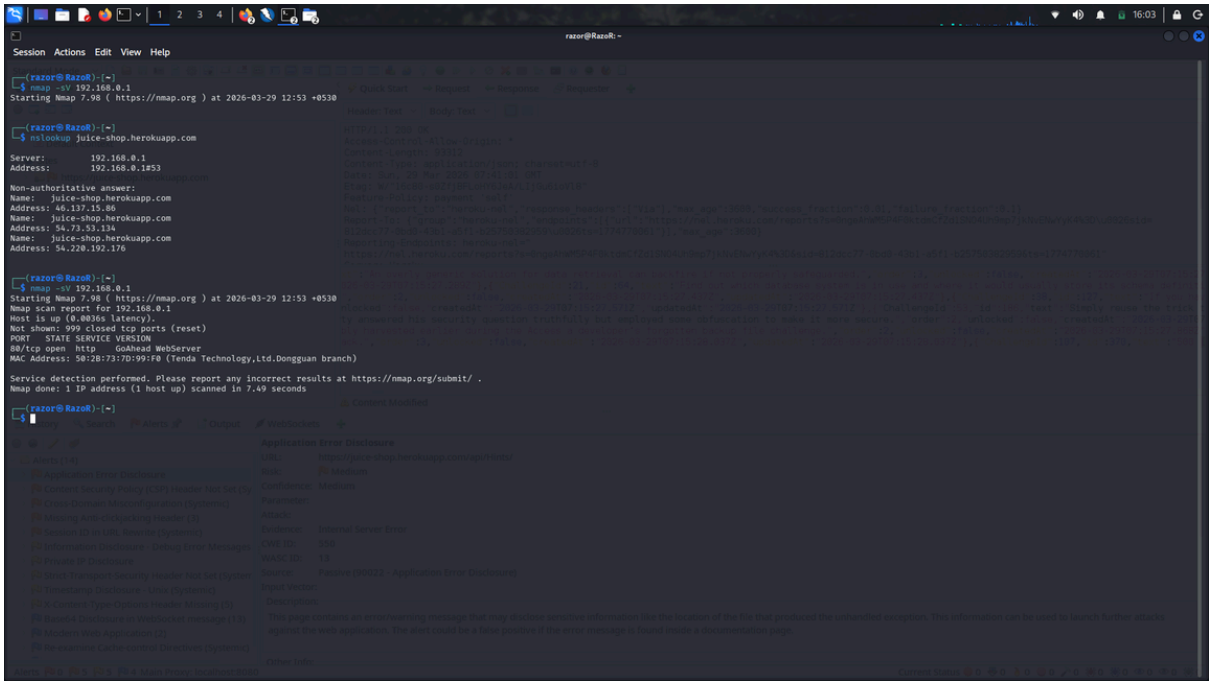
Recommendation: Use secure cookies or headers for session management.

Screenshots






Untitled Session - 20260329-130932 - ZAP 2.17.0
File Edit View Analyse Report Tools Import Export Online Help
Standard Mode
Sites
Quick Start
Request
Response
Requester
Contexts
Default Context
Sites
https://juice-shop.herokuapp.com
Header: Text
Body: Text
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
Content-Length: 93312
Content-Type: application/json; charset=utf-8
Date: Sun, 29 Mar 2026 07:41:01 GMT
Content Modified
History
Search
Alerts
Output
WebSockets
Alerts (14)
Application Error Disclosure
Content Security Policy (CSP) Header Not Set (Sy
Cross-Domain Misconfiguration (Systemic)
Missing Anti-clickjacking Header (3)
Session ID in URL Rewrite (Systemic)
Information Disclosure - Debug Error Messages
Private IP Disclosure
Strict-Transport-Security Header Not Set (Systerr
Timestamp Disclosure - Unix (Systemic)
X-Content-Type-Options Header Missing (5)
Base64 Disclosure in WebSocket message (13)
Modern Web Application (2)
Re-examine Cache-control Directives (Systemic)
Application Error Disclosure
URL: https://juice-shop.herokuapp.com/api/Hints/
Risk: Medium
Confidence: Medium
Parameter:
Attack:
Evidence: Internal Server Error
CWE ID: 550
WASC ID: 13
Source: Passive (90022 - Application Error Disclosure)
Input Vector:
Description:
This page contains an error/warning message that may disclose sensitive information like the location of the file that produced the unhandled exception. This information can be used to launch further attacks against the web application. The alert could be a false positive if the error message is found inside a documentation page.
Other Info:
Alerts 0 5 5 4 Main Proxy: localhost:8080
Current Status


razor@RazoR: ~
Session Actions Edit View Help
(razor㉿RazoR)-[~]
$ nmap -sV 192.168.0.1
Starting Nmap 7.98 (https://nmap.org) at 2026-03-29 12:53 +0530
(razor㉿RazoR)-[~]
$ nslookup juice-shop.herokuapp.com
Server: 192.168.0.1
Address: 192.168.0.1#53
Non-authoritative answer:
Name: juice-shop.herokuapp.com
Address: 46.137.15.86
Name: juice-shop.herokuapp.com
Address: 54.73.53.134
Name: juice-shop.herokuapp.com
Address: 54.220.192.176
(razor㉿RazoR)-[~]
$ nmap -sV 192.168.0.1
Starting Nmap 7.98 (https://nmap.org) at 2026-03-29 12:53 +0530
Nmap scan report for 192.168.0.1
Host is up (0.0036s latency).
Not shown: 999 closed tcp ports (reset)
PORT STATE SERVICE VERSION
80/tcp open http GoAhead WebServer
MAC Address: 50:2B:73:7D:99:F8 (Tenda Technology,Ltd.Dongguan branch)
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.49 seconds
(razor㉿RazoR)-[~]
$

Recommendations

- Implement modern security headers.
- Restrict CORS to trusted domains.
- Remove sensitive error/debug information.
- Improve session handling.
- Regularly patch and update hosting environment.

Conclusion

Juice Shop is intentionally insecure for training purposes, but this assessment highlights real-world risks that mirror common misconfigurations. Addressing these issues would significantly strengthen its security posture.